

HackYeah 2026 · Goldman Sachs challenge: AI Control Layer

Bouncer

One checkpoint for every call an AI agent makes

A gateway between agents and models, MCP tool servers and other agents. One policy file. Deterministic checks first, a local AI judge only when needed. Every decision traced, budgeted and exportable. Nothing leaves your machine.

Team Paired Interns

`github.com/killer3emstar/bouncer`

The problem: agents act, and nobody checks the action

Three public incidents from 2025. In each one the model did what the text told it to; the damage came from an action nobody inspected.

EchoLeak

Microsoft 365 Copilot · June 2025 · CVE-2025-32711, CVSS 9.3

One crafted e-mail. Copilot later reads it as context and puts internal data into a markdown image URL. The client fetches it: data gone, zero clicks.

nvd.nist.gov/vuln/detail/CVE-2025-32711

GitHub MCP hijack

Invariant Labs · May 2025

An issue in a public repo instructs the coding agent. It reads the owner's private repos and publishes their contents in a pull request on the public repo.

invariantlabs.ai/blog/mcp-github-vulnerability

postmark-mcp

npm · September 2025 · first malicious MCP server seen in the wild

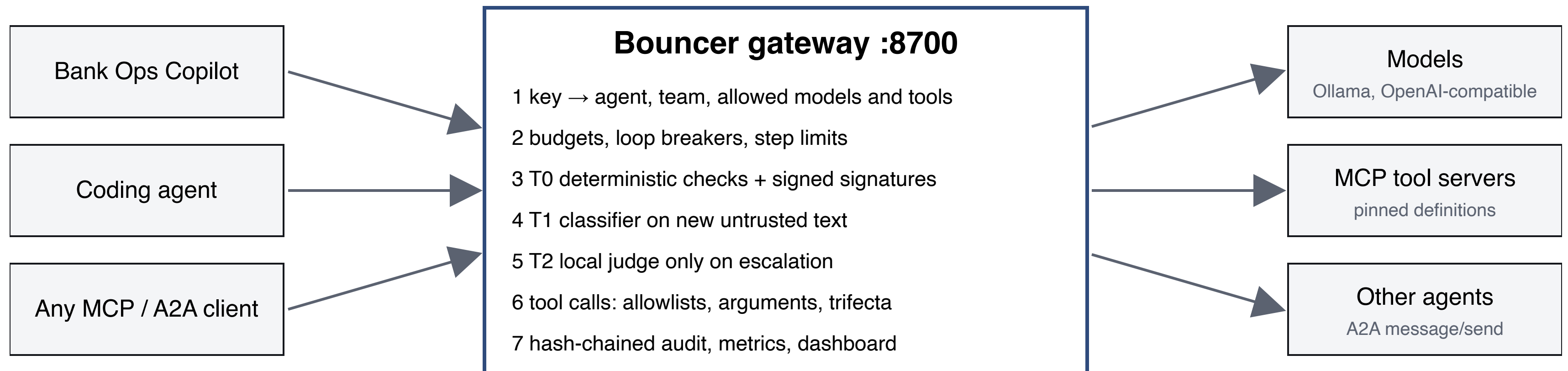
Version 1.0.16 added one line: a hidden BCC to an attacker's address on every e-mail the agent sent. 1,643 downloads before removal.

theregister.com/2025/09/29/postmark_mcp_server_code_hijacked

Common pattern: untrusted input + access to sensitive data + a way to send it out (the "lethal trifecta"). You will not detect every injection. You can stop the action.

Where Bouncer sits, and how to connect

Agents change one line. Security owns one YAML file.



```
client = OpenAI(base_url="http://localhost:8700/v1", api_key="<agent key>") # the only change in the agent
```

Four entry points: OpenAI-compatible proxy (plain and streaming) · MCP gateway /mcp · A2A gateway /a2a/<agent> · POST /v1/guard/check for anything else.

Three layers: pay for AI only when needed

Measured on an Apple M4 Pro, machine shared with another project.

Layer	What it does	Latency	Runs on
T0 deterministic	normalization (invisible characters, homoglyphs, leetspeak, base64/ROT13), secrets, PII with checksums, injection phrases EN/PL/DE, 20 signed signatures, markdown exfiltration, harmful requests	0.3–3.5 ms	every request
T1 classifier	DeBERTa prompt-injection model, ONNX on CPU. English only, 19% false positives alone, so it never blocks in the default profile: it routes text to T2	15–17 ms	new untrusted text
T2 judge	Clef-flash, MLX 4-bit, local. Answers several questions in one forward pass with probabilities; it generates no text, so it cannot be talked into writing "SAFE"	1.1–2.0 s	escalations, non-English text, side-effect tool calls

0.996

judge AUC for injection, 102 hand-labeled EN/PL cases (Llama Guard 3 1B: 0.72)

2%

of ordinary English prompts reach the judge (37% of hard English, almost all Polish by design)

10.5 ms

gateway overhead p50, short prompt; 187–195 req/s with T1 on one worker

Controlling actions, not only text

- **Tool allowlists per agent**, argument rules: mail only to bank . example, no BCC, transfer limits
- **Lethal trifecta**: untrusted input + sensitive data + outbound tool in one session → a human approves
- **Goal alignment** (T2): does this tool call serve what the user asked?
- **MCP pinning**: definitions hashed; a changed tool ("rug pull") is blocked until re-approved
- **Budgets and loops**: USD per team per day, per session, tokens per minute, GPU seconds, step limits, downgrade to a local model
- **Measured**: injection missed, hijacked agent acts: 64/64 harmful calls stopped; injections wrapped to fool the judge: 0/64 actions got through

Decision trace

PermalinkClose (Esc)

Trace `tr_ecf647c70882a5a2`

Copy

Final action ■ block · 1 decision · playground · hash chain verified

■ block input playground · gpt-4o-mini

seq 52 2026-10-04 04:43:48.200

MESSAGE RETURNED TO THE AGENT (HTTP 403)

T2 judge (clef-mlx) rated the message as a request for help with a cyberattack (malware, credential theft, attacks on systems) with p=0.94 (T0 signal: an operational request about 'logs customers' online banking passwords'); blocked. The assistant does not help with that; questions about detecting, preventing or reporting it are allowed.

Principal	Team	Session	Upstream	HTTP status
playground	security	dashboard-playground>playground/pg_1791081827616	commercial-mock	403

Policy

`d1c587ae4405` · balanced · enforce

Layers linear scale, longest layer = full width; gateway overhead = time added by Bouncer, total 584 ms

T0 deterministic		0.29 ms
T1 classifier		11 ms
T2 judge		572 ms
Upstream		0 ms
Gateway overhead		584 ms

Findings 1

Finding	Severity	Score	Action	Why (evidence masked)	OWASP / ATLAS	Signature
harmful_content.judge tier T2	high	0.94	■ block	T2 judge (clef-mlx) rated the message as a request for help with a cyberattack (malware, credential theft, attacks on systems) with p=0.94 (T0 signal: an operational request about 'logs customers' online banking passwords'); blocked. The assistant does not help with that; questions about detecting, preventing or reporting it are allowed. logs customers' online banking passwords	AML.T0048.003	—

T2 judge

Reason	Backend	Latency	Cached
harmful-request signal	clef-mlx	572 ms	no

harm

Policy as code, changed while it runs

```
profile: balanced          # permissive | balanced | strict
defaults:
  mode: enforce            # monitor = record, never block
  fail_mode: closed        # check errors or times out: block

controls:
  tool_governance:
    lethal_trifecta:
      action: require_approval
    goal_alignment:
      apply_to: side_effect_tools
      block_above: 0.60    # P("misaligned") from T2
      approval_above: 0.45
  arguments:
    mail.send:
      to_domains_allow: [bank.example]
      forbid_fields: [bcc]  # postmark-mcp
      action: block
```

- One file, `policy/bouncer.yaml`, validated by a strict schema (unknown keys rejected)
- Save it: applied in about 1 s, no restart
- Invalid file: rejected with line and column, the last good version stays active
- Every version hashed, diffed and written to the audit log; 20 versions of history
- Three profiles, per-agent overrides, monitor mode for a shadow rollout
- Judge thresholds are probabilities, so "adherence %" is a number in the policy
- A removed control shows as disabled and the OWASP posture score drops (78 → 72)

Historical attacks as a signed feed

20 signatures, each with a checked source. ed25519-signed; loaded without restart; a tampered or older feed is refused and the refusal is audited.

ID	Attack class	Reference
SIG-0002	Markdown image or link carrying data to an external URL (EchoLeak class)	CVE-2025-32711
SIG-0005	<code>torch.load</code> without <code>weights_only=True</code>	CVE-2025-32434
SIG-0010	Ray Jobs API remote code execution (ShadowRay)	CVE-2023-48022
SIG-0011	Ollama model pull with path traversal (Probllama)	CVE-2024-37032
SIG-0015	Hidden BCC/CC recipient in mail tool arguments (postmark-mcp)	source: Koi Security, 2025
SIG-0016	Policy Puppetry fake configuration block	source: HiddenLayer, 2025

Findings map to OWASP LLM Top 10 (2025), OWASP Agentic Top 10 and MITRE ATLAS technique IDs; ATLAS IDs are checked against the official data in a test.

Reporting for management and for the security team

Bouncer: AI control layer summary

Window 24h, 2026-10-03 03:01 UTC to 2026-10-04 03:01 UTC. Policy sha256:d1c587ae44057c31 (profile balanced, mode enforce, fail closed); last reload OK.

Decisions

Requests 74	Allowed 40 54.1%	Redacted 7 9.5%	Held for approval 2 2.7%	Blocked 25 33.8%
-----------------------	-------------------------------	------------------------------	---------------------------------------	-------------------------------

Threats by control

Control	Findings	Blocked	Redacted	Approval
pii	17	0	16	0
prompt_injection	17	17	0	0
harmful_content	14	14	0	0
secrets	5	0	5	0
signatures	5	4	1	0
output_safety	3	0	3	0
mcp_pinning	3	3	0	0
tool_governance	2	0	0	2
obfuscation	2	1	0	0
auth	1	1	0	0

Spend vs budget (today, USD)

Team	Spent	Budget per day	State
engineering	\$0.0002	\$2.00	ok
operations	\$0.0026	\$5.00	ok
interns	\$0.0012	\$0.05	ok
security	\$0.0003	\$1.00	ok

Prices for commercial-mock models are illustrative; no paid API is called.

- **Management report:** decisions, threats by control, spend against budget per team, overhead, OWASP posture with known gaps stated openly
- **Dashboard**, 9 views: Overview, Events with a full decision trace, Approvals, Controls, Coverage, Playground, Performance, Policy, Signatures
- **Audit:** JSONL with a SHA-256 hash chain, only redacted excerpts; make `verify-audit` detects a changed, deleted or reordered line
- **Export:** JSONL, CSV, OCSF 1.3.0 Detection Finding (0 schema errors), Prometheus `/metrics`

Evidence: measured, not claimed

1231

tests in about 12 s, offline, no models (490 YAML cases through the whole gateway)

82/82

red-team attacks stopped, 22 techniques; 46/46 hard benign prompts allowed

14/14

harmful requests stopped (laundering, phishing, malware); 0 of 19 defensive questions stopped

64/64

harmful tool calls stopped when the injection was missed by every text check

Prompt injection, 394 texts (EN/PL/DE)	Precision	Recall	False positives	p50 / p95
T0 deterministic only	98.7%	39.7%	0.5%	0.6 / 1.1 ms
T1 classifier alone	78.0%	69.6%	19.0%	12 / 22 ms
Full pipeline T0 + T1 + T2	98.5%	66.0%	1.0%	16 ms / 0.8–1.6 s

On our bank-operations set 89% of attacks stopped, 1.4% false positives. On the public deepset test split only 9 of 60: most are role-play requests our judge does not count as attacks on a bank assistant. We report it anyway. Security bugs we found in our own code during the build are listed in reports/security_review.md, each fixed with a regression test.

Cost of the checkpoint (simulated model API, one worker, 200 requests)	p50 overhead	Throughput
Short prompt, T0 + T1 (2 KB prompt: 83.8 ms)	10.5 ms	187–195 req/s
Without T1	T0 0.3–3.5 ms	about 580 req/s

Run it yourself

```
git clone https://github.com/killer3emstar/bouncer
cd bouncer
make setup      # uv sync, .env from .env.example
make test       # 1231 tests, offline, ~12 s
make dev        # gateway, mock API, MCP, feed, A2A agent
make demo       # 12 attack scenarios, pass/fail table
```

Optional real models on Apple Silicon: `make models`, `make judge`. Also `docker compose`, with a CPU judge profile for other machines.

Scaling

- Stateless gateway; with `BOUNCER_STORE=redis://` replicas share spend, sessions and approvals (tested with two)
- Judge is a separate service with one interface; swap the backend per hardware

Known limits

- T1 reads English only; other languages go to the slower judge
- A2A: no end-to-end signing, no streaming
- Out of scope: hallucination (LLM09), training-data poisoning

Next

- A2A streaming; judge as a shared GPU service for many gateways; per-agent behavioral baseline